Information Security and Access Control Policy

Acme Tech Solutions Inc.

Field	Value
Version	3.2
Effective date	January 15, 2026
Policy owner	Daniel Ortiz, Director of Information Security
Approved by	Robert Hale, Chief Executive Officer
Review cycle	Reviewed and approved at least annually

1. Purpose and Scope

This policy defines the security requirements for protecting Acme and customer information. It applies to all employees, contractors, and systems that store, process, or transmit Acme or customer data.

2. Roles and Responsibilities

The Director of Information Security owns this policy and the security program. System owners are accountable for access to their systems. All personnel are responsible for complying with this policy.

3. Data Classification and Protection

3.1 Customer data is classified as Confidential.

3.2 Confidential data at rest is encrypted using AES-256.

3.3 Data in transit over public networks is encrypted using TLS 1.2 or higher.

4. Access Control

4.1 Access is provisioned through an approved ticket and granted based on least privilege.

4.2 Multi-factor authentication is enforced for all interactive access to Acme systems, including administrative interfaces and remote access.

4.3 Shared accounts are prohibited except where technically required and approved by the Director of Information Security.

4.4 Access for terminated personnel is removed within one business day of termination.

4.5 User access rights to production systems are reviewed at least quarterly by system owners.

4.6 Administrative privileges are granted through separate administrative accounts that are not used for email or web browsing.

5. Logging and Monitoring

5.1 Security-relevant events from production systems are sent to a central SIEM and retained for at least 12 months.

6. Vulnerability Management

6.1 Authenticated vulnerability scans of production are performed at least monthly.

6.2 An independent third party performs an external penetration test at least annually.

6.3 Critical vulnerabilities are remediated within 15 calendar days of identification. High vulnerabilities are remediated within 30 calendar days. Medium vulnerabilities are remediated within 90 calendar days.

7. Incident Response

7.1 Acme maintains an incident response plan that is reviewed and tested at least annually.

7.2 Affected customers are notified within 72 hours of Acme confirming a security incident involving their data.

8. Security Awareness

8.1 All personnel complete security awareness training upon hire and annually thereafter.

8.2 Phishing simulations are conducted quarterly for all personnel.

9. Business Continuity

9.1 Acme maintains business continuity and disaster recovery plans for the Managed IT Services Platform, which are tested annually.

10. Records Retention

10.1 Acme business records, including invoices and contracts, are retained for seven years.

11. Third Parties

11.1 Vendors with access to customer data are assessed before onboarding and annually thereafter. AWS is the hosting provider for the Managed IT Services Platform.

12. Exceptions and Enforcement

12.1 Exceptions to this policy must be documented and approved by the Director of Information Security. Violations may result in disciplinary action.